

The 5W Security Framework

Why justifies it?

Who owns it?

What controls it?

Where is the threat?

When do we act?

– Then back to *why*

ISO 27001 ISMS (PDCA) with NIST CSF (PDCA aligned)

Foundation:

Order	Domain	W	Question	Framework	Subject	PDCA
1	Governance	Why	Why does it matter?	NIST RMF	Risk Management	Plan
2	Governance	Who	Who owns it?	RACI	Accountability	Plan
3	Risk & Control	What	What controls it?	NIST 800-53 Rev 5	Control Selection	Do
4	Threat Intelligence	Where	Where is the threat?	MITRE ATT&CK v15	Threat Intelligence	Check
5	Cyber Operation	When	When do we act?	NIST CSF 2.0	Defensive Lifecycle	Act
■	Loop	Why	What changed?	NIST RMF	Continuous Improvement	Plan

Note: The PDCA column shows Why and Who both mapping to Plan, and the loop back to Why also mapping to Plan. Plan appears multiple times because governance and risk management never stop.

Supporting Domains:

Domain	Framework	Subject	PDCA
Cyber Risk	FAIR	Risk Quantification	Plan
Project & Task	PMBOK + Agile	Program Delivery	Do
Communication	RACI + BLUF	Stakeholder Alignment	Act

The Engine:

Layer	Sample Technologies	Subject	PDCA
Technology Enablement	SIEM, EDR, SOAR ZT, DevSecOps, IaC	Execution Capability	All

Note: The | separates operational detection/response tools (SIEM, EDR, SOAR) from engineering and architecture practices (ZT, DevSecOps, IaC).

© 2026 Adam McKinski. Some rights reserved.

"The 5W Security Framework" is an original work by Adam McKinski.

Licensed under Creative Commons Attribution-NonCommercial 4.0 International

License (CC BY-NC 4.0) | <https://creativecommons.org/licenses/by-nc/4.0/>

You may share and adapt this work for non-commercial purposes, provided you attribute Adam McKinski. Commercial use is prohibited without written permission.